

Assignment 1: Build a Mini Secure Fintech Wallet

Group Size: 2–3 students

Objective

The purpose of this assignment is to design and develop a small fintech wallet while applying the secure-system-design concepts discussed in class.

The emphasis is not only on developing a functional application, but also on understanding:

- what can go wrong in your system;
- which assets need protection;
- where security weaknesses exist;
- what could happen if those weaknesses are exploited; and
- what controls can reasonably reduce those risks.

Important: You are not given a fixed list of security controls to implement. Each group must analyze its own application, identify relevant security weaknesses, and select suitable controls.

1. Application Scenario

Develop a small digital fintech wallet. The application should allow a user to perform the following basic operations:

1. Create/use a customer account.
2. Log in to the wallet.
3. View the current account balance.
4. Transfer funds to another registered user.
5. View previous transactions.
6. Log out of the application.

The application may be implemented as a web application, mobile application, or client-server application. You may use any reasonable programming language, framework, and database technology.

Note: A sophisticated user interface is not required. Marks will primarily be awarded for system design, functionality, security analysis, and implementation.

2. Basic Functional Requirements

Customer Account

Each customer should have an identifiable account within the system.

Authentication

The system should have a mechanism for determining which user is accessing the wallet.

Wallet Balance

A user should be able to see their current balance.

Fund Transfer

A user should be able to transfer an amount to another registered wallet.

Ali → Rs. 2,000 → Sara

After a successful transfer:

- Ali's balance should decrease;
- Sara's balance should increase; and
- the transaction should appear in the relevant transaction records.

Transaction History

Users should be able to view their previous transactions. At minimum, a transaction record should identify information such as:

- sender,
- receiver,
- amount,
- date/time, and
- transaction status.

3. Security Analysis

This is the most important part of the assignment. Before deciding which security controls to implement, analyze your system and identify its important assets and potential weaknesses.

Possible assets could include:

- User credentials
- Customer identity information
- Wallet balance
- Transaction information
- Account information
- Application data
- Logs

You are expected to identify the assets relevant to your own implementation.

4. Identify Security Weaknesses

Identify security weaknesses that could affect your fintech wallet. Think about questions such as:

- Can one customer access another customer's information?
- Can someone modify another customer's balance?
- Can transactions be manipulated?
- Can credentials be exposed?
- Can unauthorized users perform sensitive operations?
- Can important information be modified without detection?
- What happens if invalid or unexpected input is submitted?
- What happens if part of the system fails?
- Is sensitive information unnecessarily exposed?
- Are privileged operations properly separated from normal operations?
- Can important actions occur without being recorded?

These are examples only. You are expected to perform your own analysis rather than simply reproducing this list.

5. Propose and Implement Security Controls

For each important weakness identified, propose an appropriate security control. The choice of controls is deliberately left open.

What should be protected, what could go wrong, and what is the most appropriate way to protect it?

Different groups may therefore implement different controls. A good security decision should have a clear relationship between:

Asset → Weakness → Possible Impact → Proposed Control

Asset	Weakness	Possible Impact	Proposed Control
Wallet balance	An unauthorized user may be able to modify another customer's balance	Financial loss and integrity violation	Students determine an appropriate control

The purpose is not simply to name a security technology. You must explain why the proposed control addresses the identified weakness.

6. Security Weakness and Control Documentation

Each group should maintain a Security Design Table for the application. Use approximately the following structure:

ID	Asset / Component	Identified Weakness	Possible Impact	Proposed Control	How Control Was Implemented	Result
W1	...	...	...	...	...	...
W2	...	...	...	...	...	...
W3	...	...	...	...	...	...

Students should clearly explain each entry. For example, simply writing “We used encryption” is insufficient. Instead, explain:

- What information required protection?
- What weakness existed?
- Why was the selected control appropriate?
- Where was the control implemented?
- What changed after implementing it?

7. Before-and-After Security Testing

For selected weaknesses, demonstrate what happens before and after the proposed control is implemented.

Before the Control

Show how the weakness could affect the system.

Implement the Control

Introduce your proposed security mechanism.

After the Control

Repeat the same test and demonstrate that the control prevents or reduces the problem.

Weakness → Demonstration → Control → Retest

Example: an unauthorized operation succeeds before the control; after the security mechanism is added, the same unauthorized operation is rejected.

You are not required to perform sophisticated penetration testing. The purpose is to demonstrate that you understand the weakness and that your proposed control actually addresses it.

8. Secure-System-Design Principles

Your report should explain how your design relates to relevant principles discussed in Unit 1, where applicable. These may include:

- Confidentiality
- Integrity
- Availability
- Authentication
- Authorization
- Least privilege
- Secure defaults
- Separation of responsibilities
- Defense in depth
- Reduction of unnecessary exposure
- Logging/accountability
- Resilience

Do not force every principle into the system. Apply only those that are relevant and justify their use.

9. Security Architecture

Provide one simple architecture diagram showing the major components of your application. For example:

User / Wallet Application → Application / Backend → Database → Transaction / Audit Information

Your actual architecture may be different. The diagram should also indicate where the major security controls have been introduced.

10. Group Contribution

Since this assignment will be completed in groups of 2–3 students, the contribution of every student must be clearly identified.

Student	Major Contribution
Student 1	Application/backend development, security control implementation
Student 2	Database, transaction functionality, security testing
Student 3	Authentication, security analysis, testing/documentation

Students should understand the complete application rather than only the portion they implemented. During the demonstration, any student may be asked questions about any part of the system.

11. Deliverables

1. Working Application

The developed fintech wallet.

2. Source Code

Complete source code with reasonable comments and instructions for running the application.

3. Report

A concise report containing the items listed below.

1. System overview
2. Architecture diagram
3. Major assets
4. Identified security weaknesses
5. Possible impact of each weakness
6. Proposed security controls
7. Explanation of implemented controls
8. Before-and-after security testing
9. Security Design Table
10. Individual student contributions
11. Limitations and possible future improvements

4. Demonstration

A live demonstration of the system and selected security decisions.

- User login/access
- Balance viewing
- Fund transfer
- Transaction history
- Selected identified weaknesses
- Implemented controls
- Before-and-after security behaviour

Students should be prepared to explain why they selected each security control.

12. Suggested Evaluation

Component	Marks
Functional Wallet Implementation	20%
Identification of Assets and Security Weaknesses	20%
Quality and Justification of Proposed Controls	20%
Implementation of Security Controls	20%
Security Testing and Before/After Demonstration	10%
Report, Architecture and Contribution Documentation	10%
Total	100%

Important: Marks will not be awarded based simply on the number of security technologies used. A smaller number of well-selected and properly justified controls is preferable to adding many security mechanisms without understanding their purpose.

Key question: *What is the weakness, why does it matter, and how does your proposed control reduce the risk?*